

Vulnerability Report

Security Level: Low

Prepared by: Seif eldeen

Target: DVWA (127.0.0.1)

Introduction

This report shows four vulnerabilities found and exploited in DVWA (Damn Vulnerable Web Application) at the Low security level, as part of a course exercise:

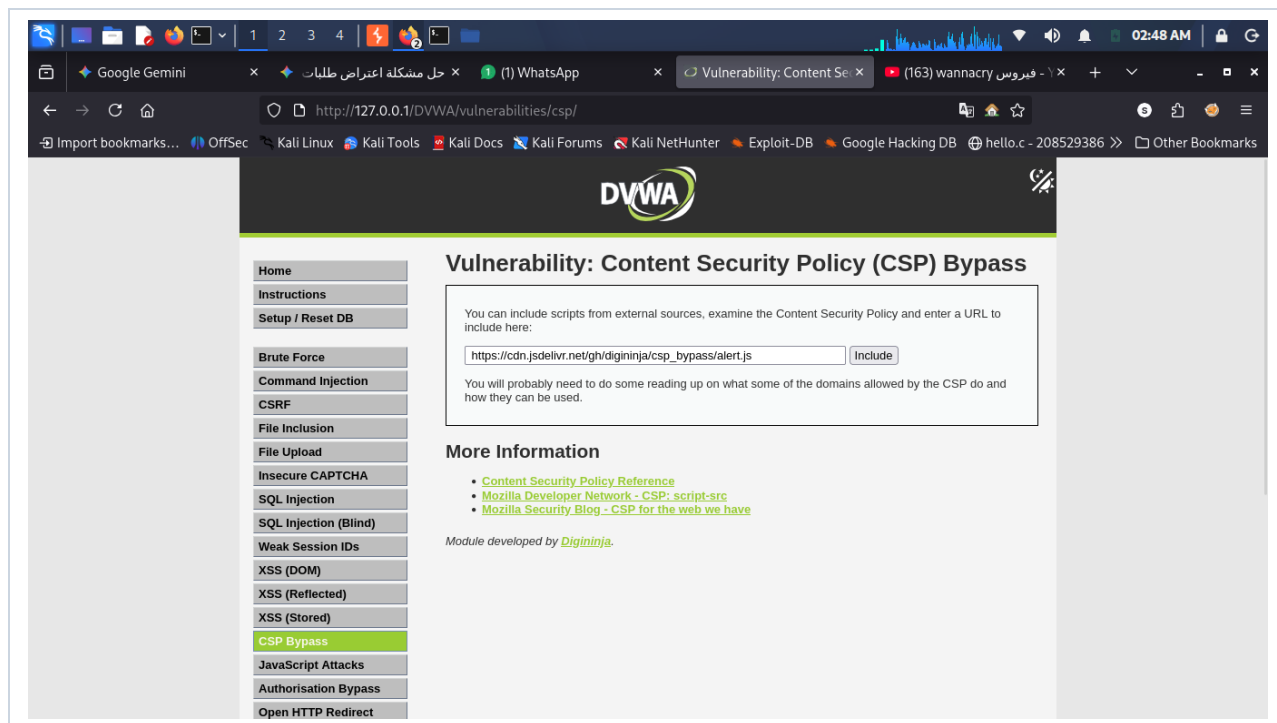
1. Content Security Policy (CSP) Bypass
2. JavaScript Attacks
3. Open HTTP Redirect
4. Authorisation Bypass

For each vulnerability, the report explains what it is and shows the steps used to exploit it, with screenshots.

1. Content Security Policy (CSP) Bypass

Content Security Policy (CSP) controls which external sources a page can load scripts from. At Low security level, DVWA allows scripts from some trusted domains, including cdn.jsdelivr.net. This can be used to load an external script and bypass the CSP protection.

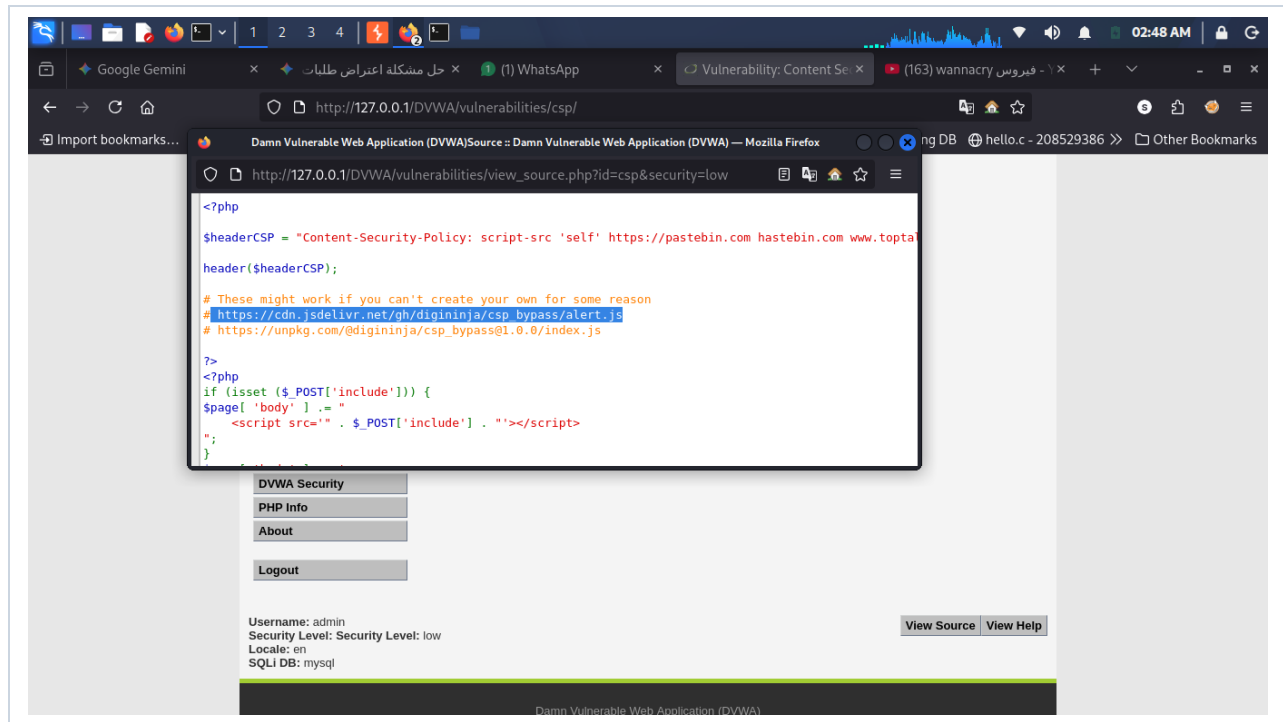
Step 1 – Open the CSP Bypass page



The CSP Bypass page before exploitation.

Step 2 – Check the source code

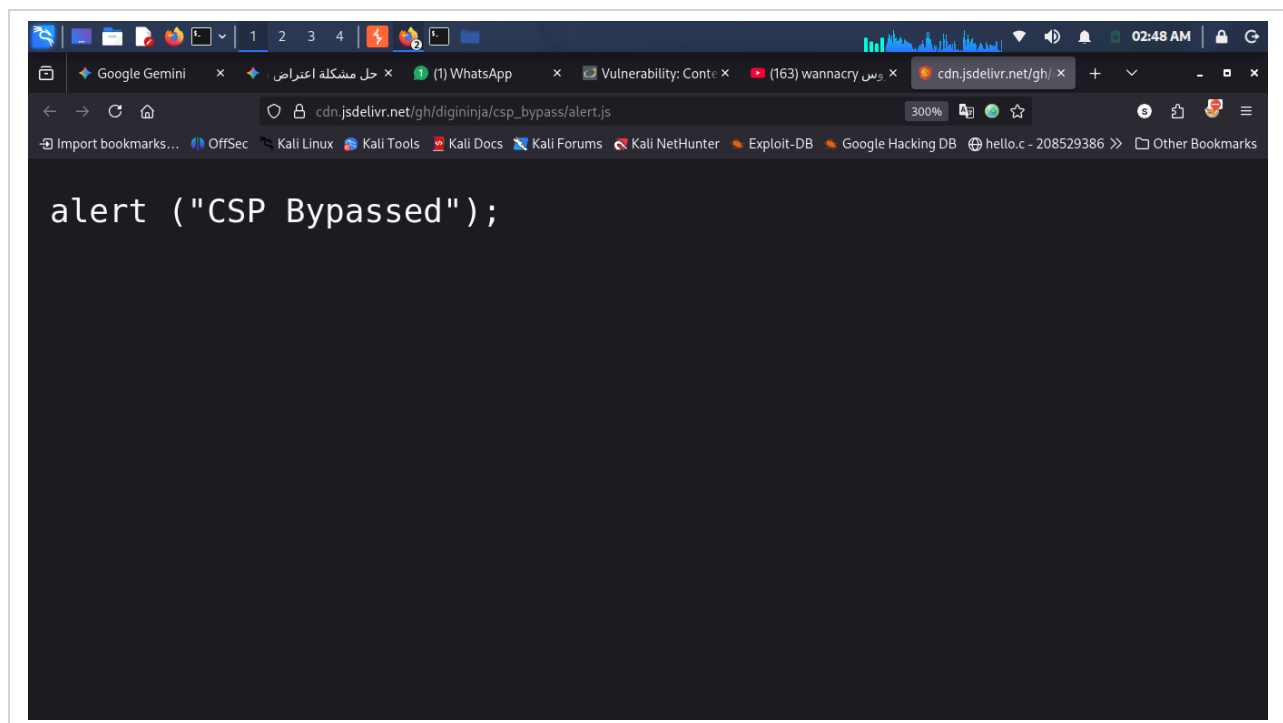
The page source shows the CSP header, which allows scripts from cdn.jsdelivr.net.



Source code showing the CSP header and allowed domains.

Step 3 – Check the external script

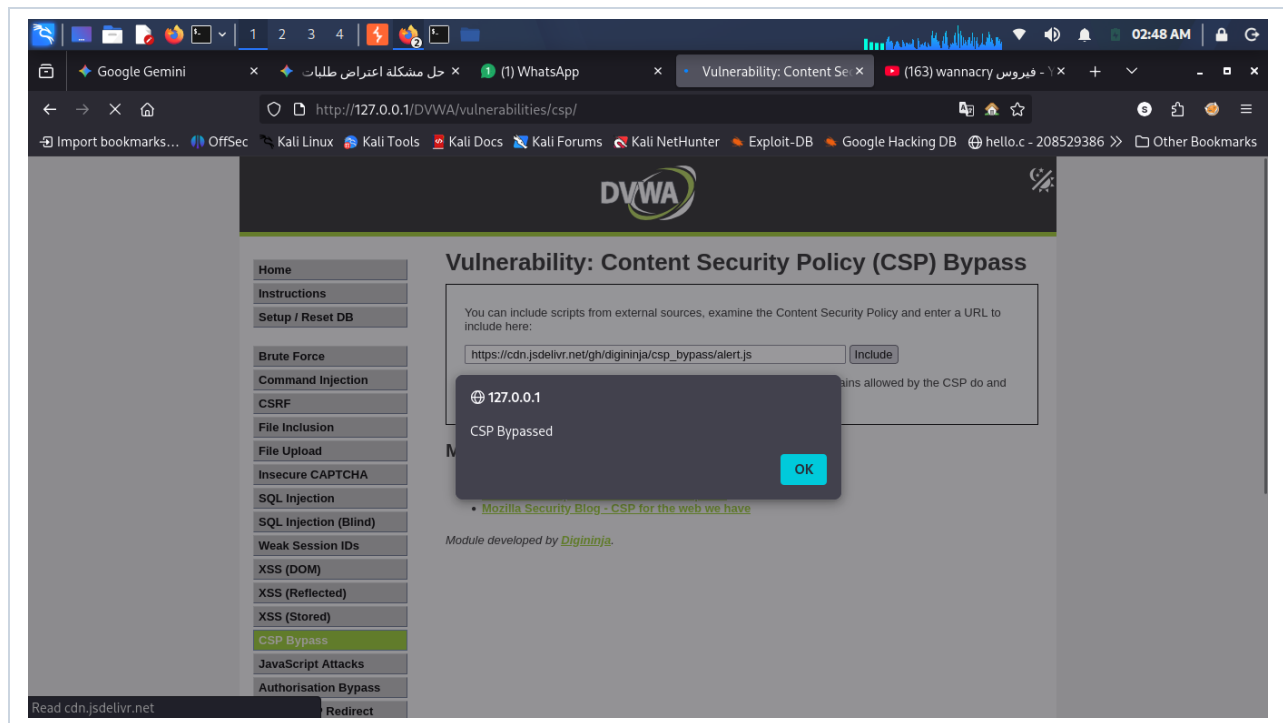
A script hosted on the allowed domain was opened. It contains a simple alert() function.



Content of the external script hosted on the allowed domain.

Step 4 – Include the script

The script URL was submitted in the Include field. The script ran successfully, proving the CSP bypass.



Alert box confirming the CSP was bypassed.

Recommendation

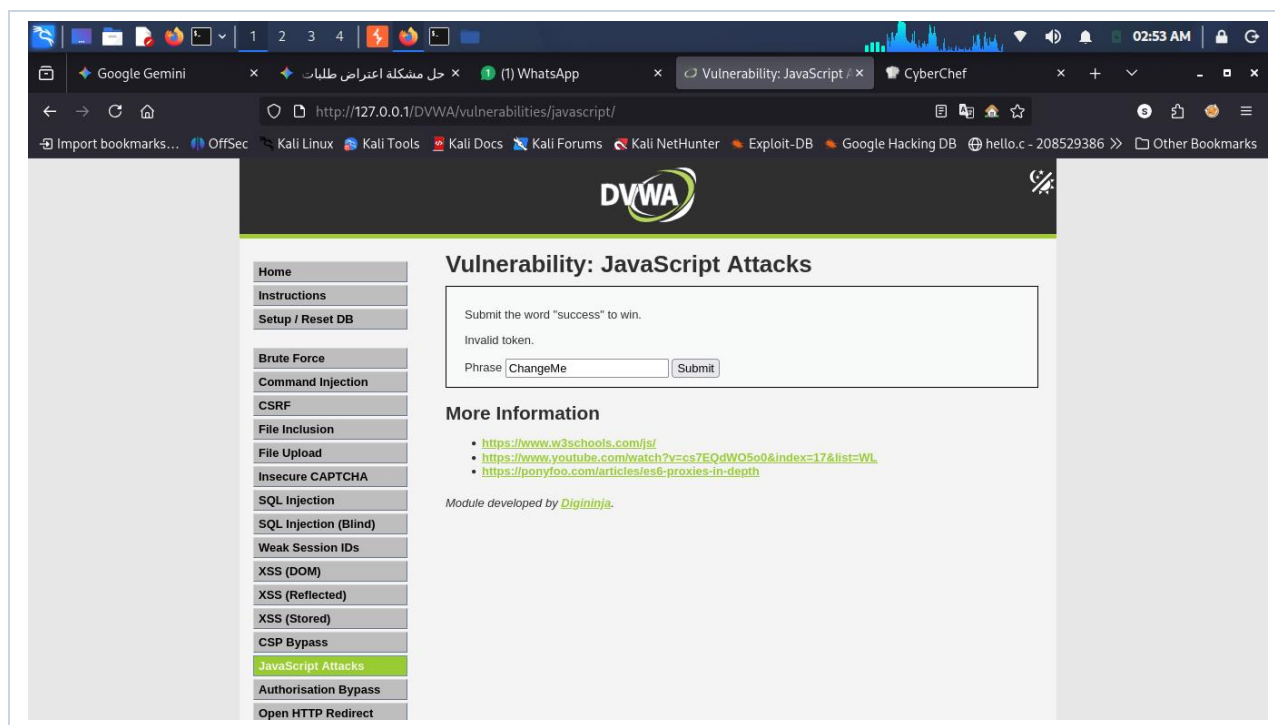
Do not allow broad third-party domains in the CSP policy. Use a strict, minimal list of trusted sources.

2. JavaScript Attacks

This challenge asks the user to submit the word "success" with a valid token. The token is generated in client-side JavaScript, using ROT13 and then MD5 on the phrase. Since the code runs in the browser, the algorithm can be read and the token can be calculated manually.

Step 1 – Test the form

Submitting the phrase with the default token gives "Invalid token".

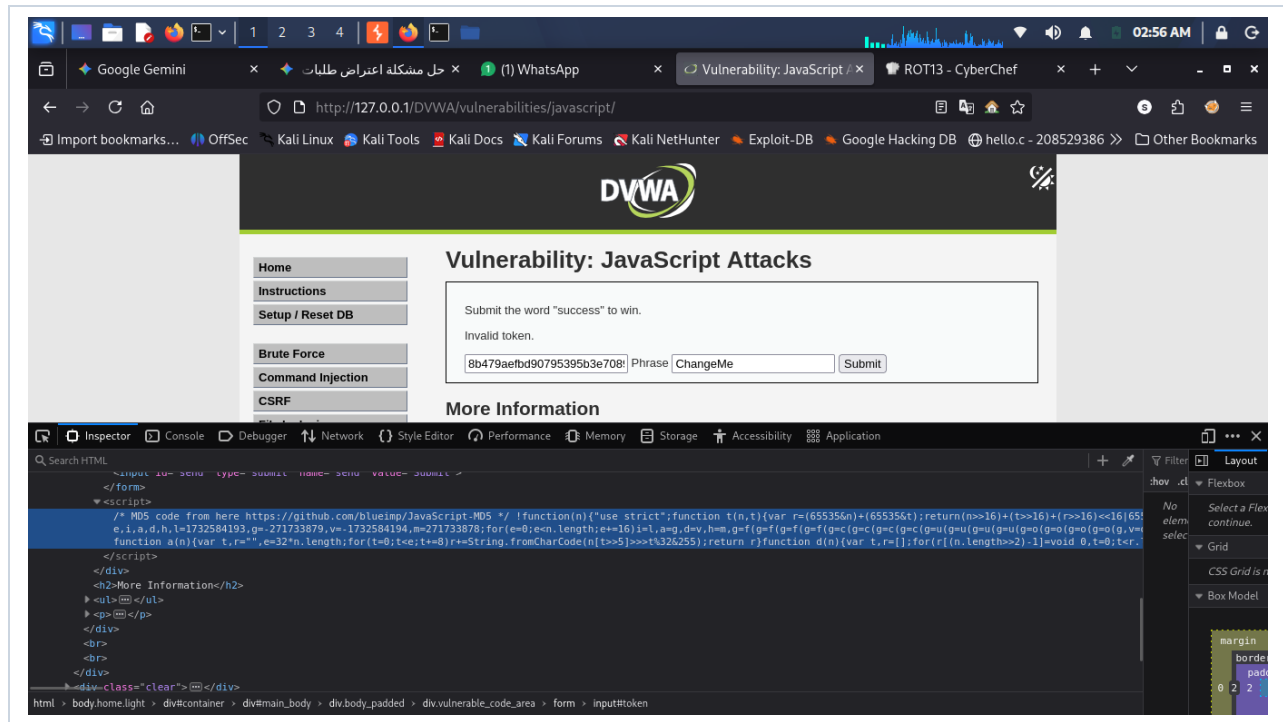


Submitting the phrase returns "Invalid token".

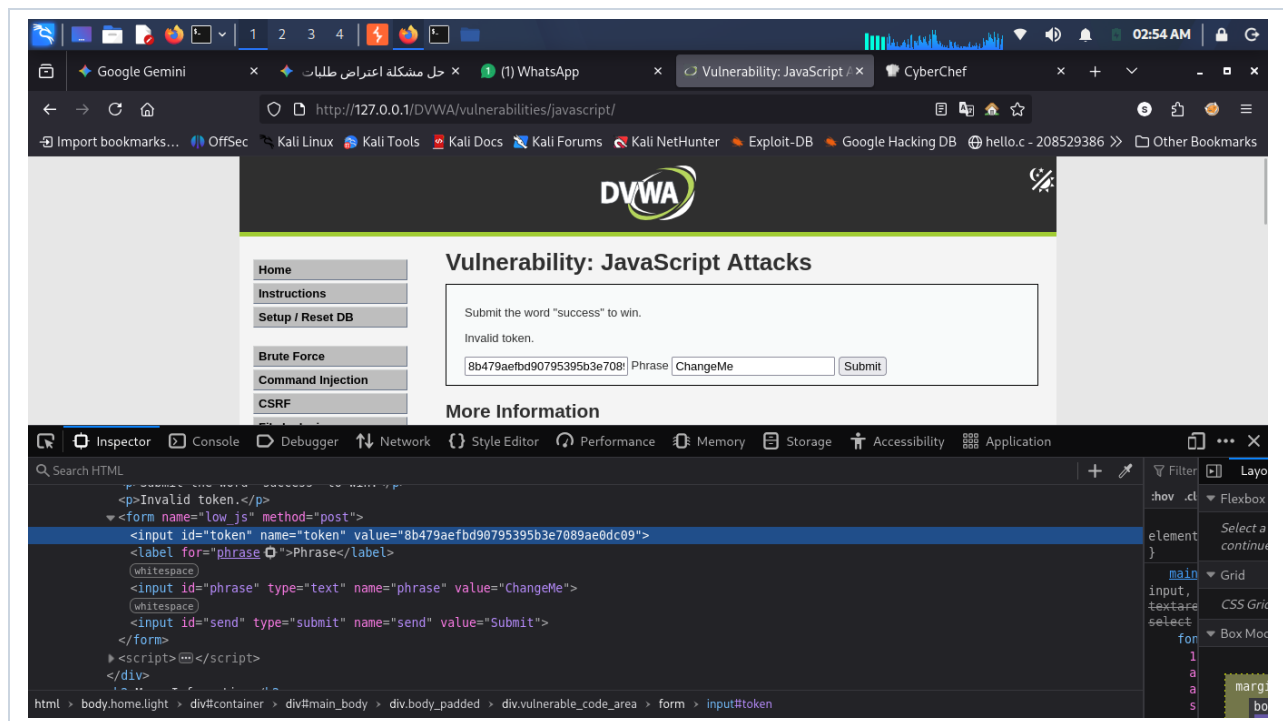


The page source contains a JavaScript function that uses ROT13 and MD5 to build the token.

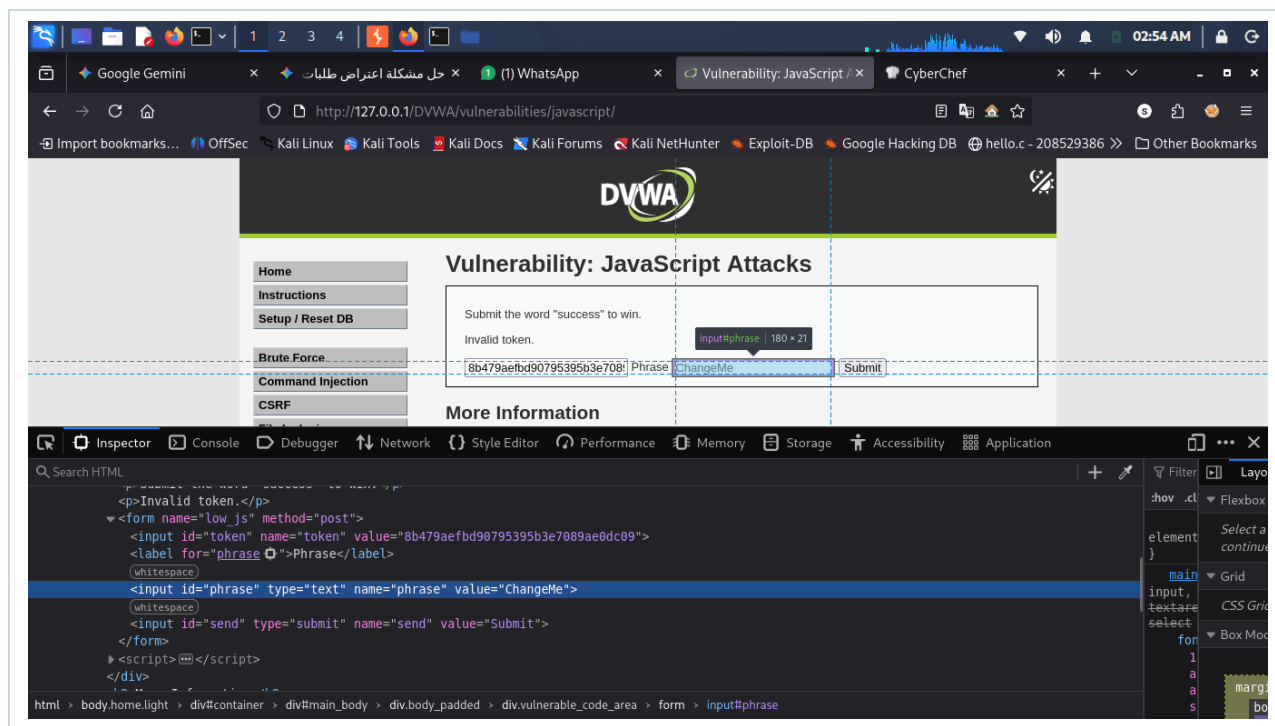




Closer look at the token script.



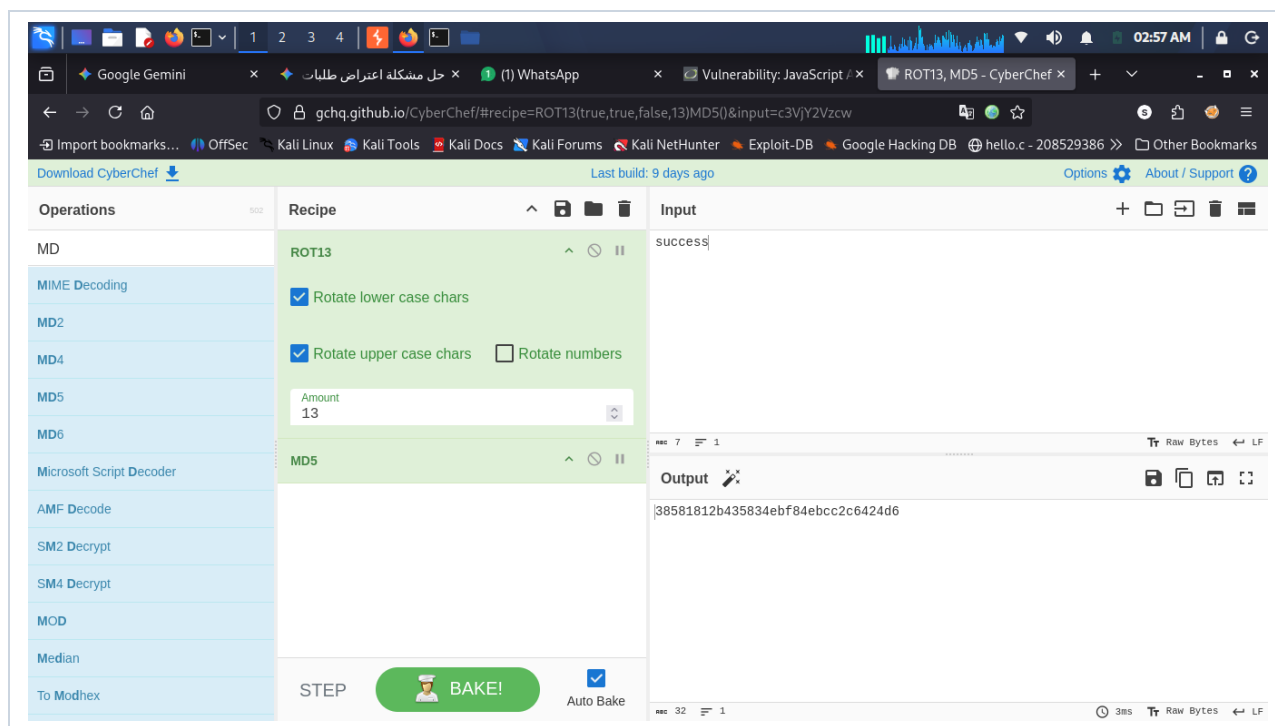
The hidden token input and its value.



Inspecting the phrase input field.

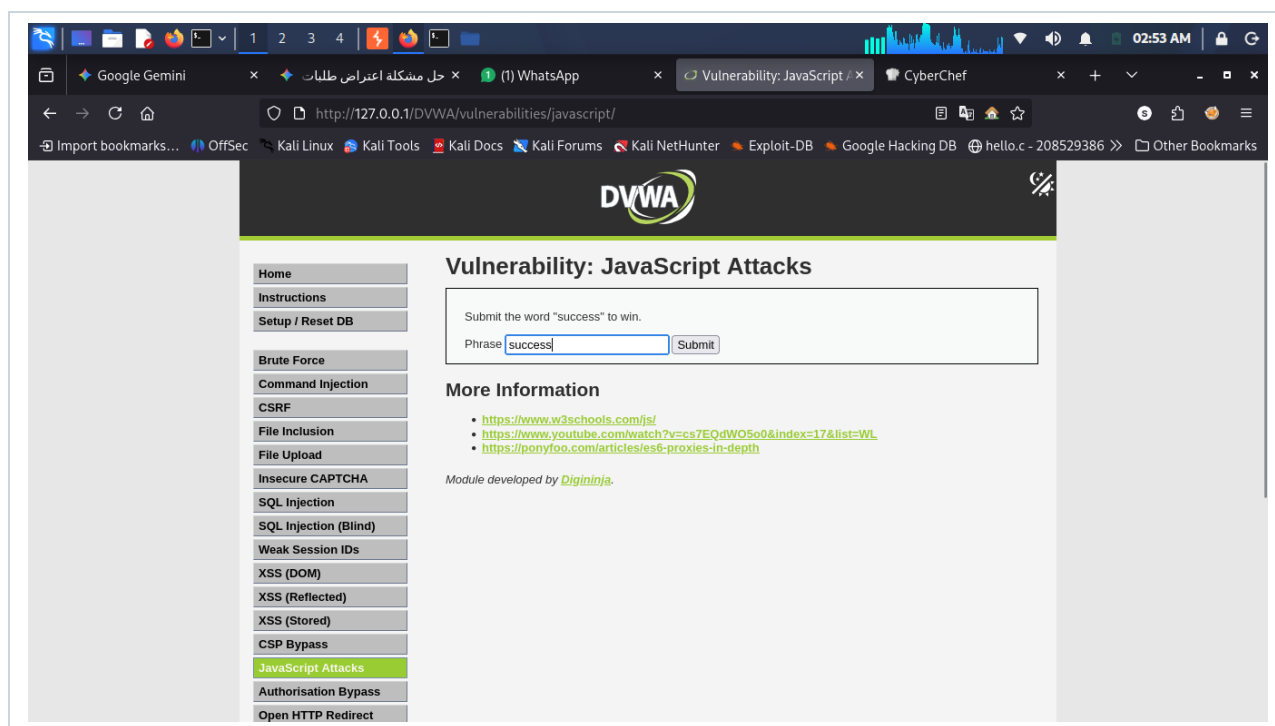
Step 3 – Calculate the correct token

CyberChef was used to apply the same steps (ROT13 then MD5) on the word "success" to get the correct token.

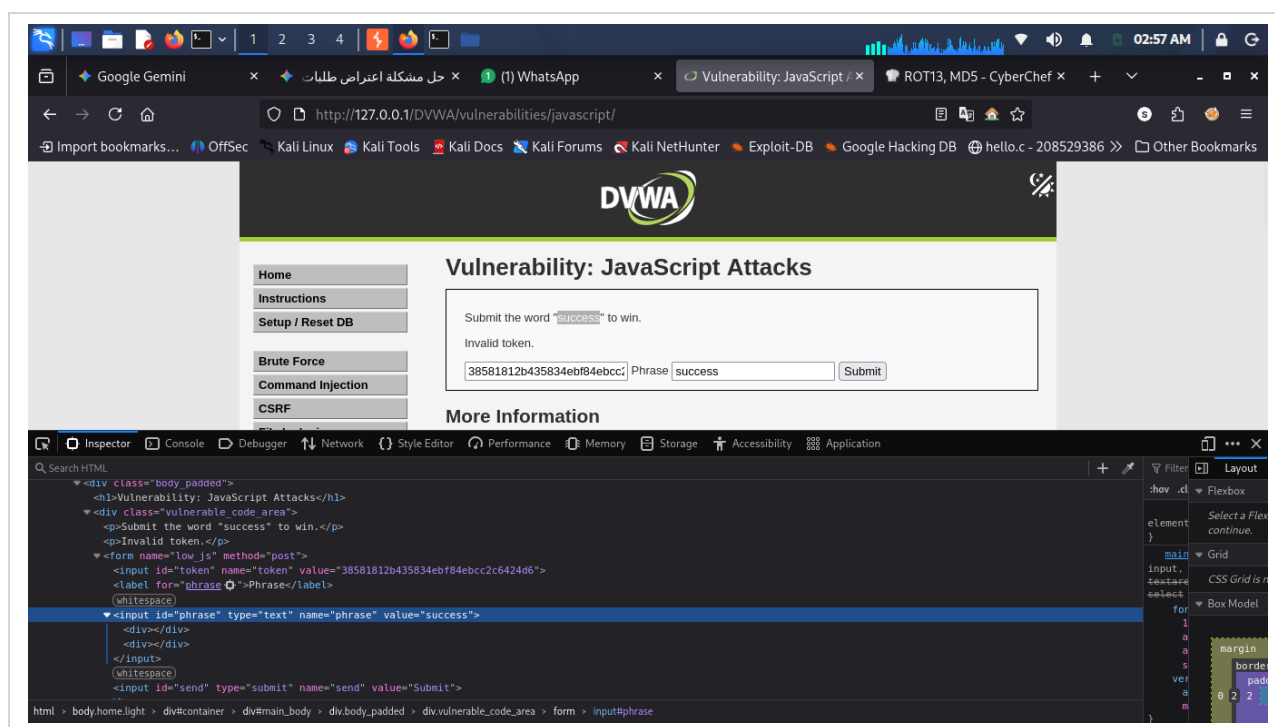


CyberChef generating the token for the phrase "success".

Step 4 – Submit the correct phrase and token



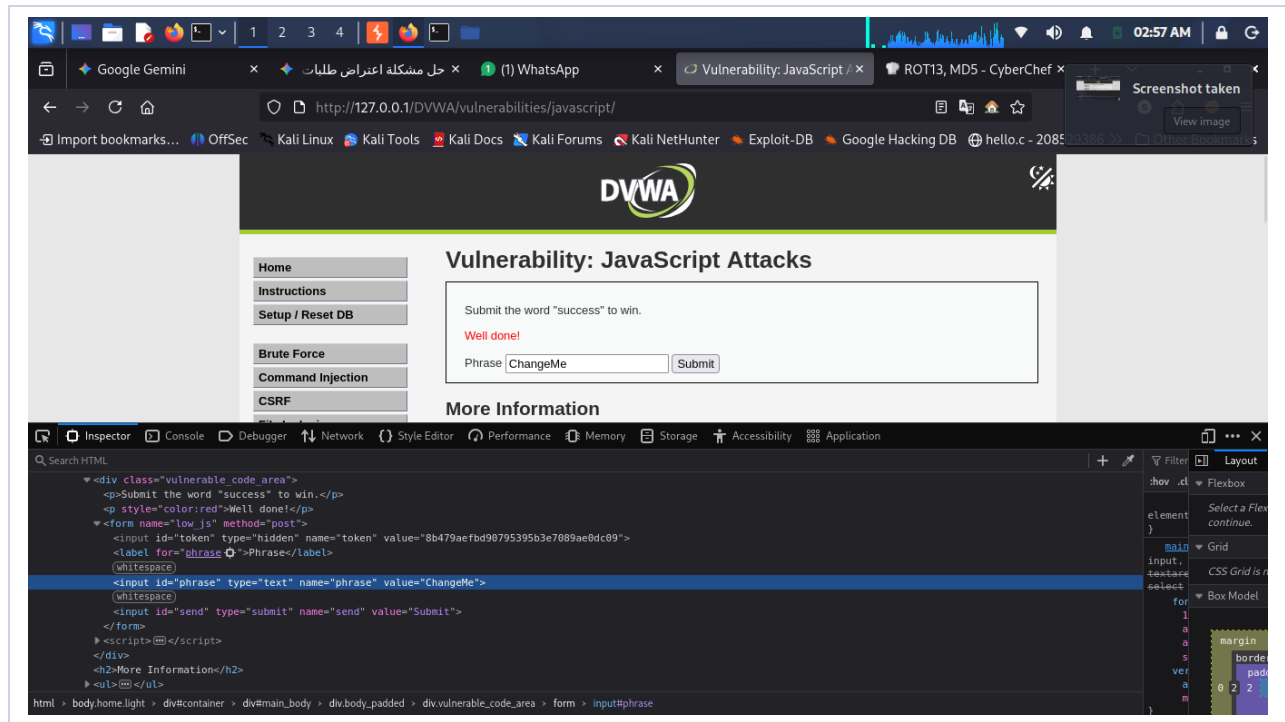
Phrase field set to "success" before submitting.



Confirming the phrase and the matching token.

Step 5 – Success

Submitting the correct phrase and token gave a "Well done!" message.



"Well done!" message confirming the bypass.

Recommendation

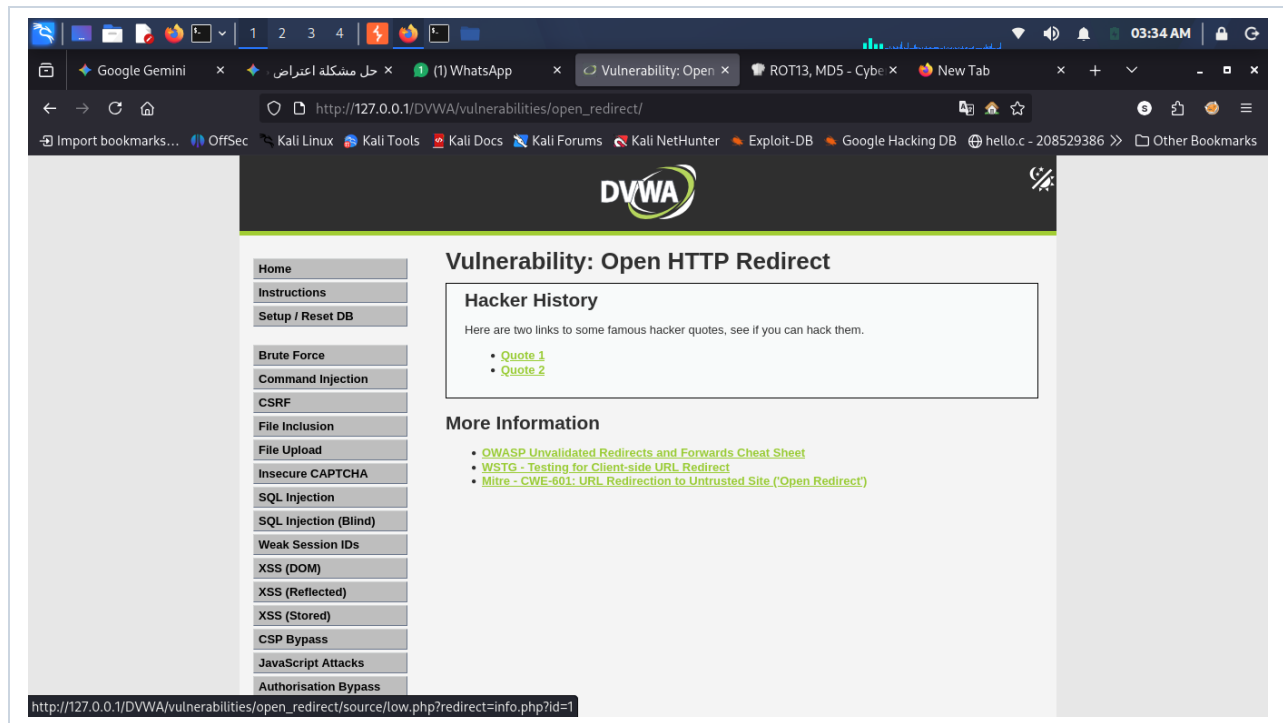
Do not use client-side JavaScript to generate or check security tokens. Generate and validate tokens on the server side.

3. Open HTTP Redirect

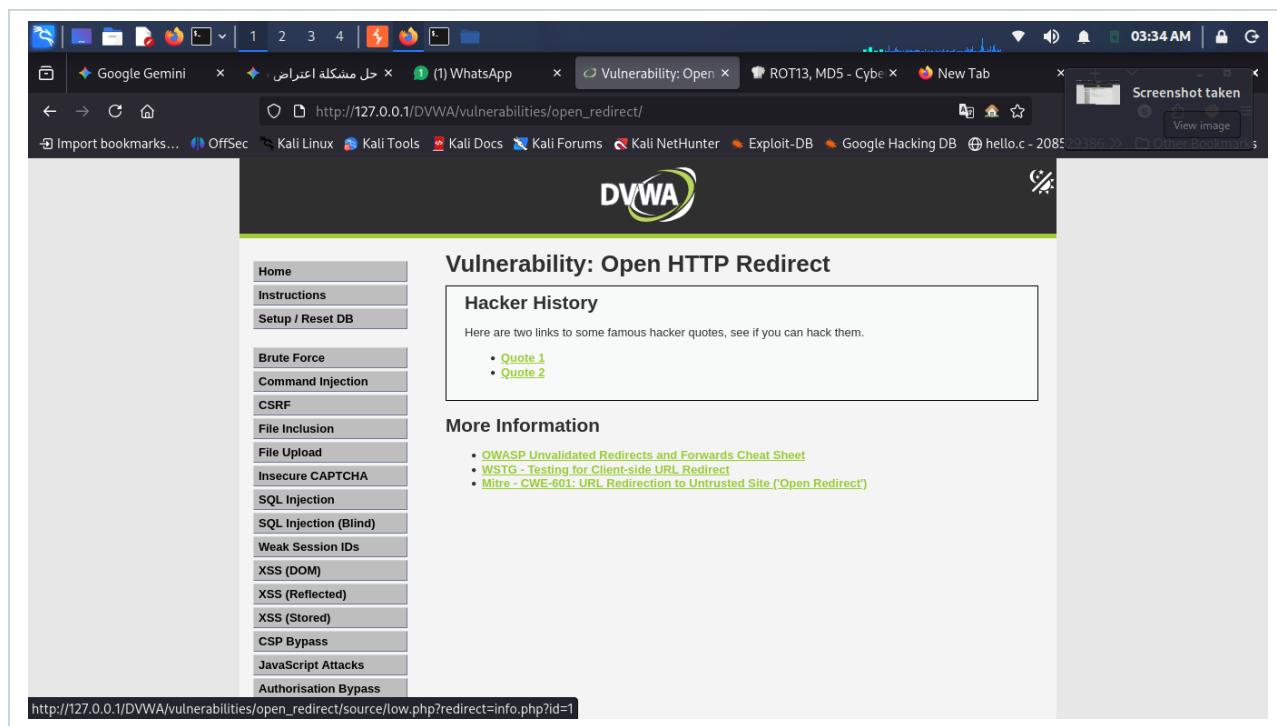
The page has links that redirect using a "redirect" parameter in the URL. At Low security level, this parameter is not checked, so it can be changed to any external website.

Step 1 – Check the redirect link

Hovering over the link shows the redirect parameter in the status bar.

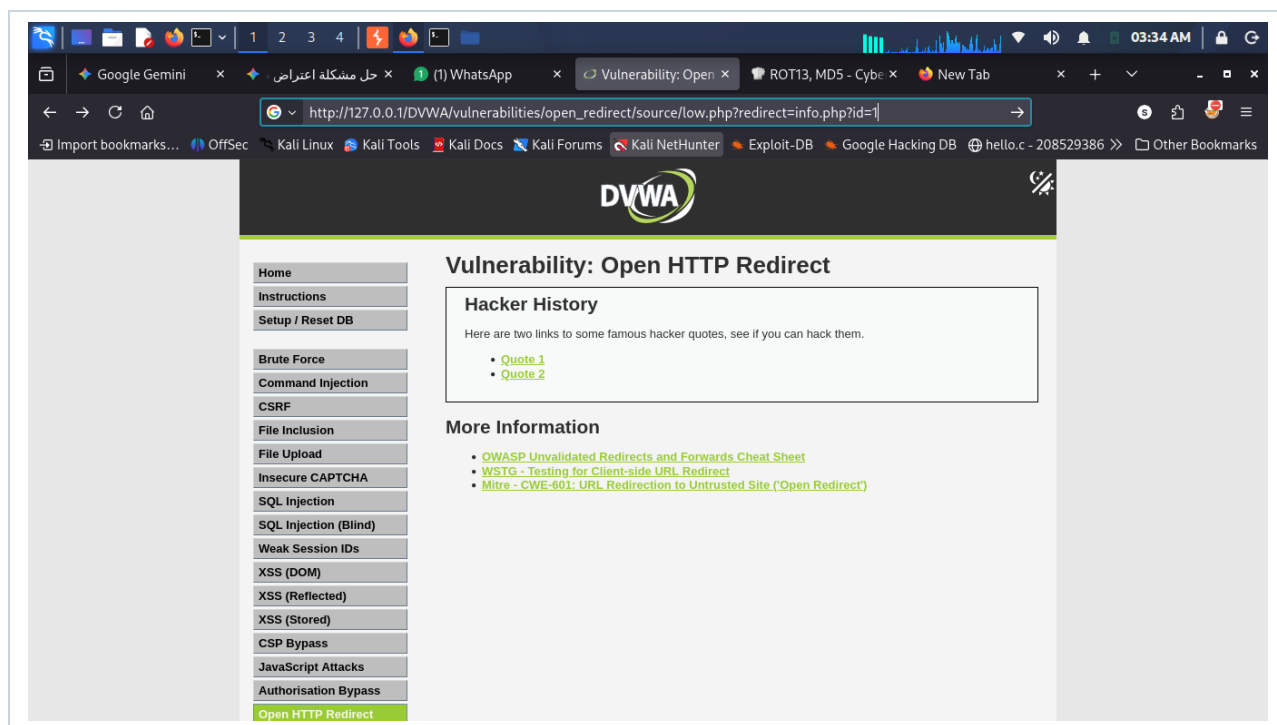


The redirect parameter shown in the status bar.



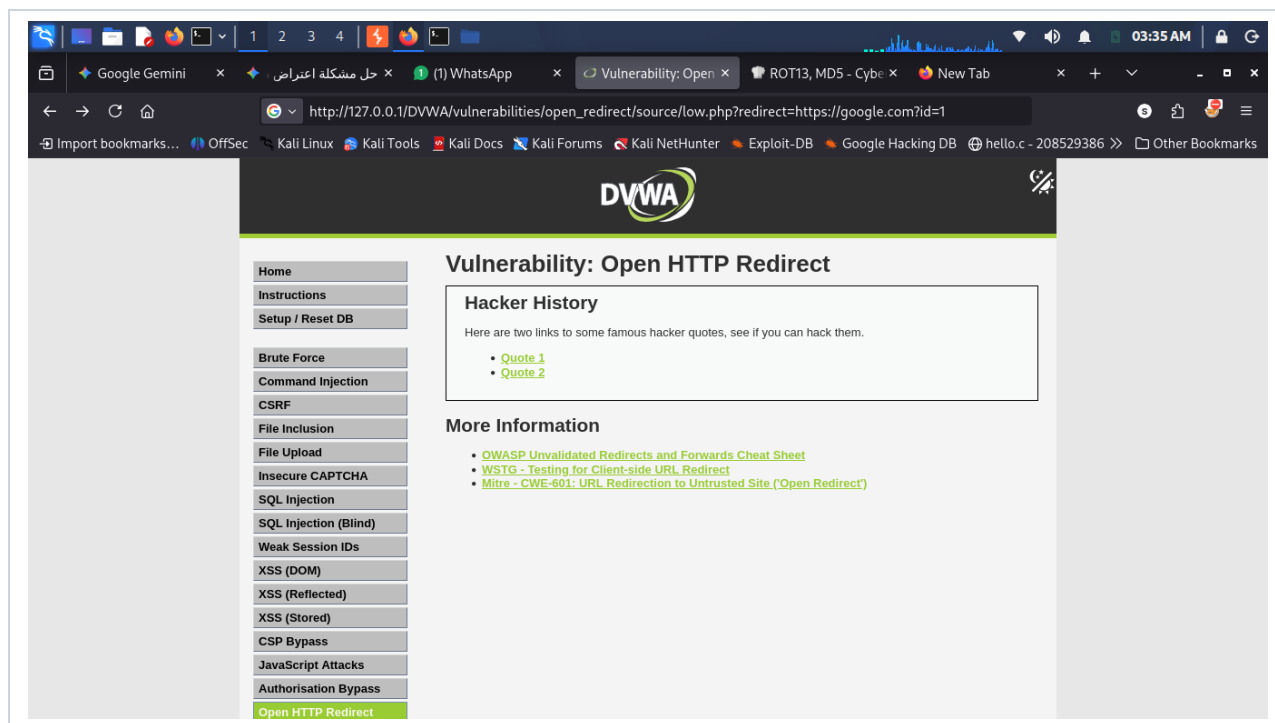
The same redirect link and parameter.

Step 2 – Change the redirect parameter



The original redirect URL.

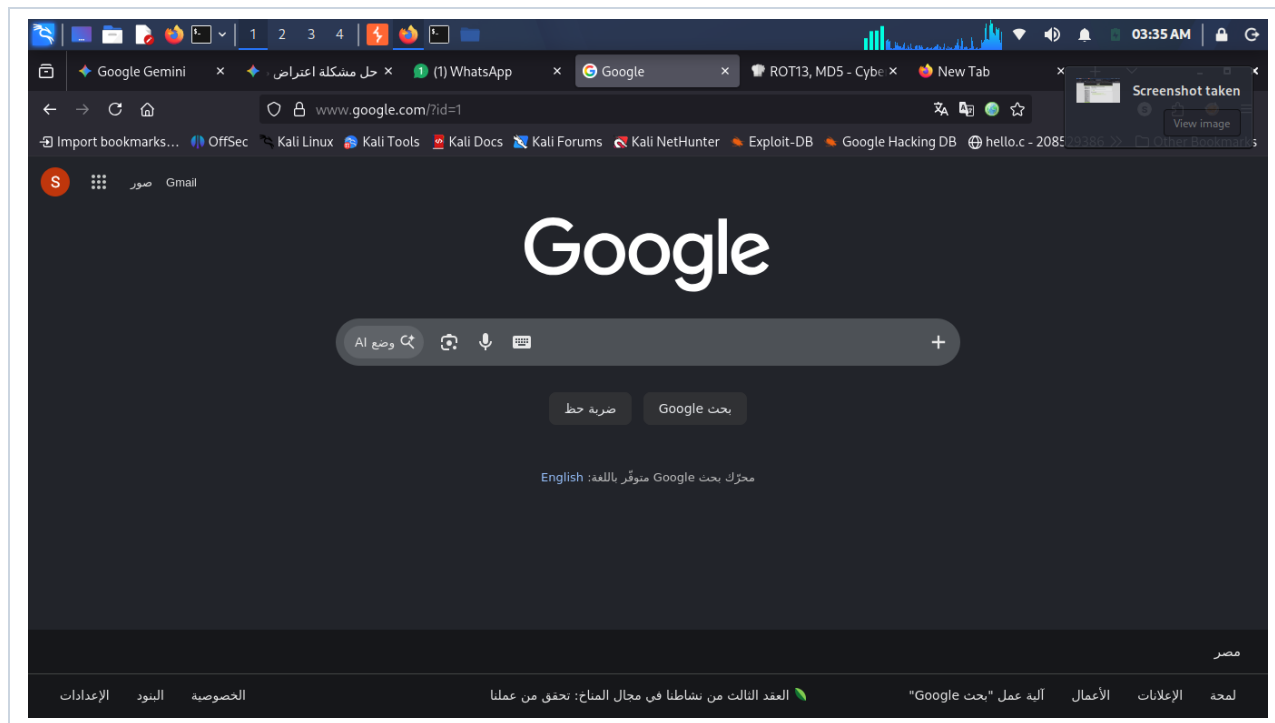
The parameter was changed to an external site (google.com).



The redirect parameter changed to point to google.com.

Step 3 – Confirm the redirect

The browser was redirected to the external site, confirming the vulnerability.



Successfully redirected to the external page.

Recommendation

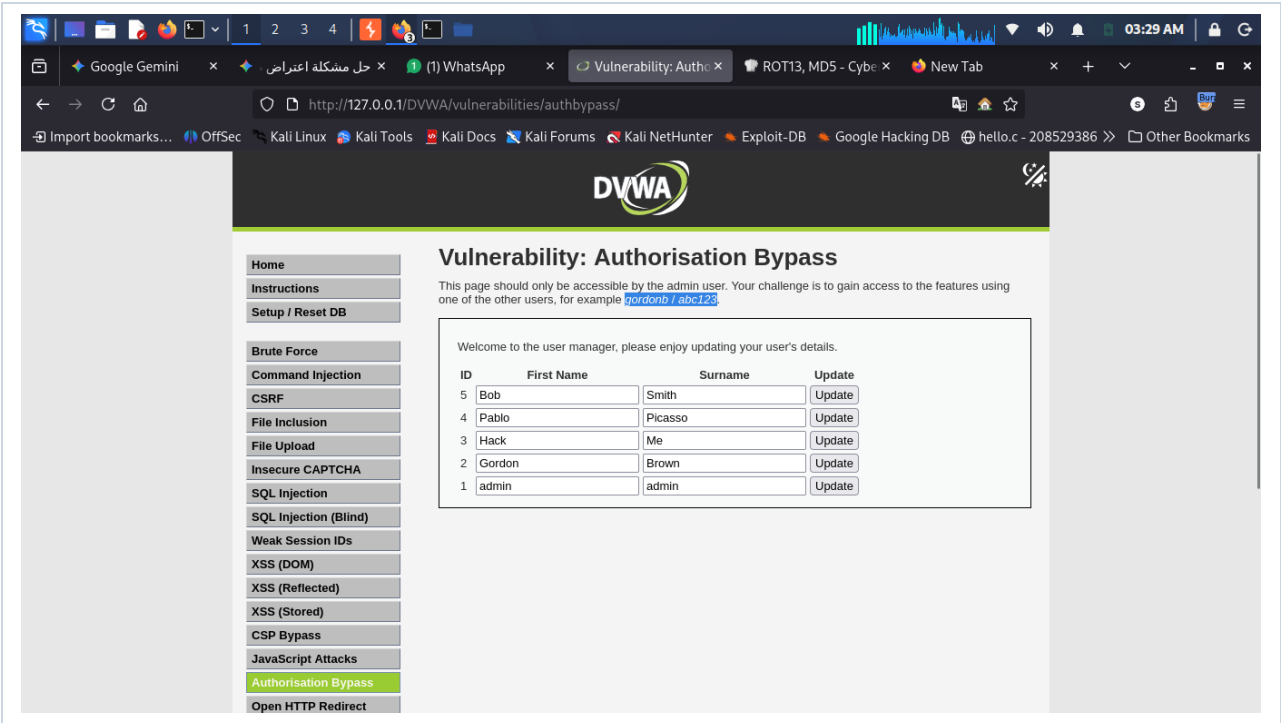
Do not use user input to build redirect URLs. Use a fixed list of allowed pages instead.

4. Authorisation Bypass

This page should only be accessible by the admin user. At Low security level, the application does not check the user role properly, so a normal user can also access it.

Step 1 – Check the hint

The page shows a low-privileged test account: gordonb / abc123.



Authorisation Bypass page showing the test credentials gordonb / abc123.

Step 2 – Intercept the request

Burp Suite was used to check the request sent to the page.

Request

Time	Type	Direction	Method	URL	Status code	Length
03:25:21.15 A...	HTTP	→ Request	OPTIONS	https://signaler-pa.clients6.google.com/punctual/multi-watch/channel?VER=8&gsessionid=85_48kmU6cUBgYhN8PK51YWMmKyv4G0Ra5K138&key=AlzaSy8WW50gh...		
03:25:26.15 A...	HTTP	→ Request	GET	http://127.0.0.1/DVWA/vulnerabilities/authbypass/		
03:25:30.15 ...	WS	→ To server		https://web.whatsapp.com/ws/chat?ED=CAMCAgF		42

Request

```

1 GET /DVWA/vulnerabilities/authbypass/ HTTP/1.1
2 Host: 127.0.0.1
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://127.0.0.1/DVWA/vulnerabilities/javascript/
8 Connection: keep-alive
9 Cookie: PHPSESSID=8e6ac54a000fc7f2edef9f7aef284b2b; security=low
10 Upgrade-Insecure-Requests: 1
11

```

Inspector

Selection: 32 (0x20)

Selected text: DVWA/vulnerabilities/authbypass/

Decoded from: Select

DVWA/vulnerabilities/authbypass/

Cancel Apply changes

Burp Suite intercepting the request to the authbypass page.

Step 3 – Log in as the normal user

Login :: Damn Vulnerable We...

http://127.0.0.1/DVWA/login.php

Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB >> Other Bookmarks

DVWA

Username

gordonb

Password

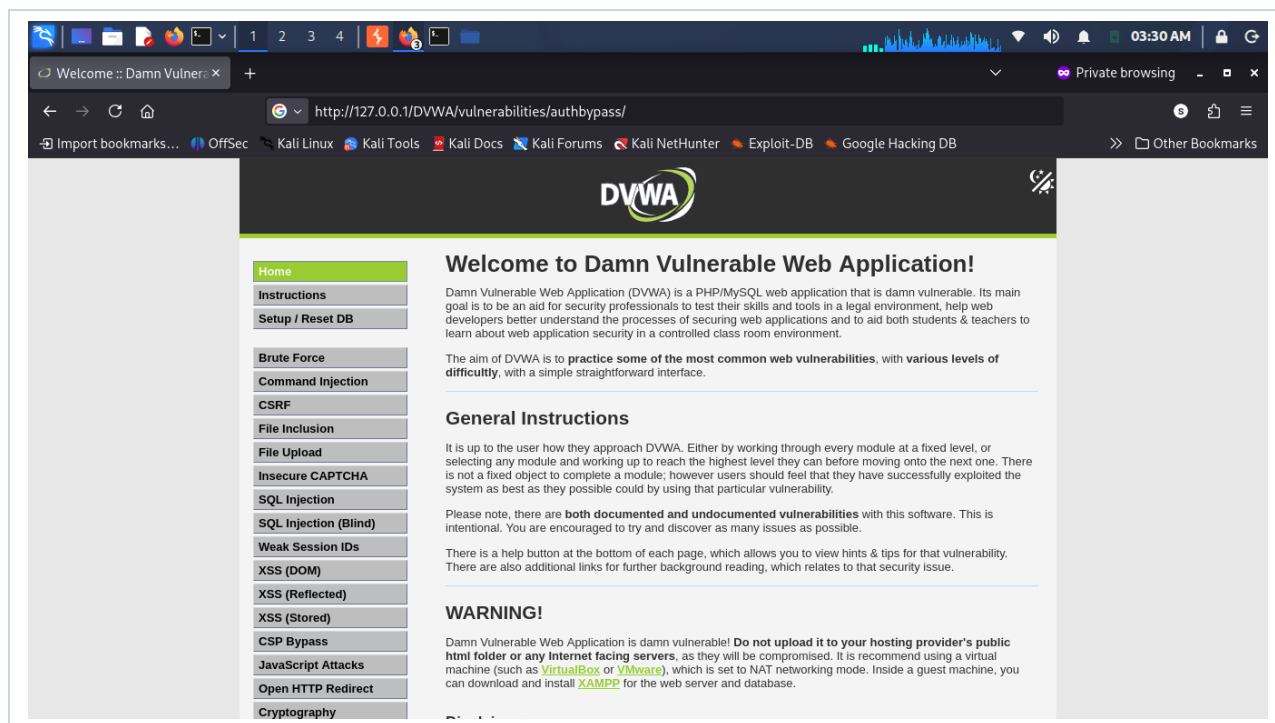
.....

Login

You have logged out

[Damn Vulnerable Web Application \(DVWA\)](#)

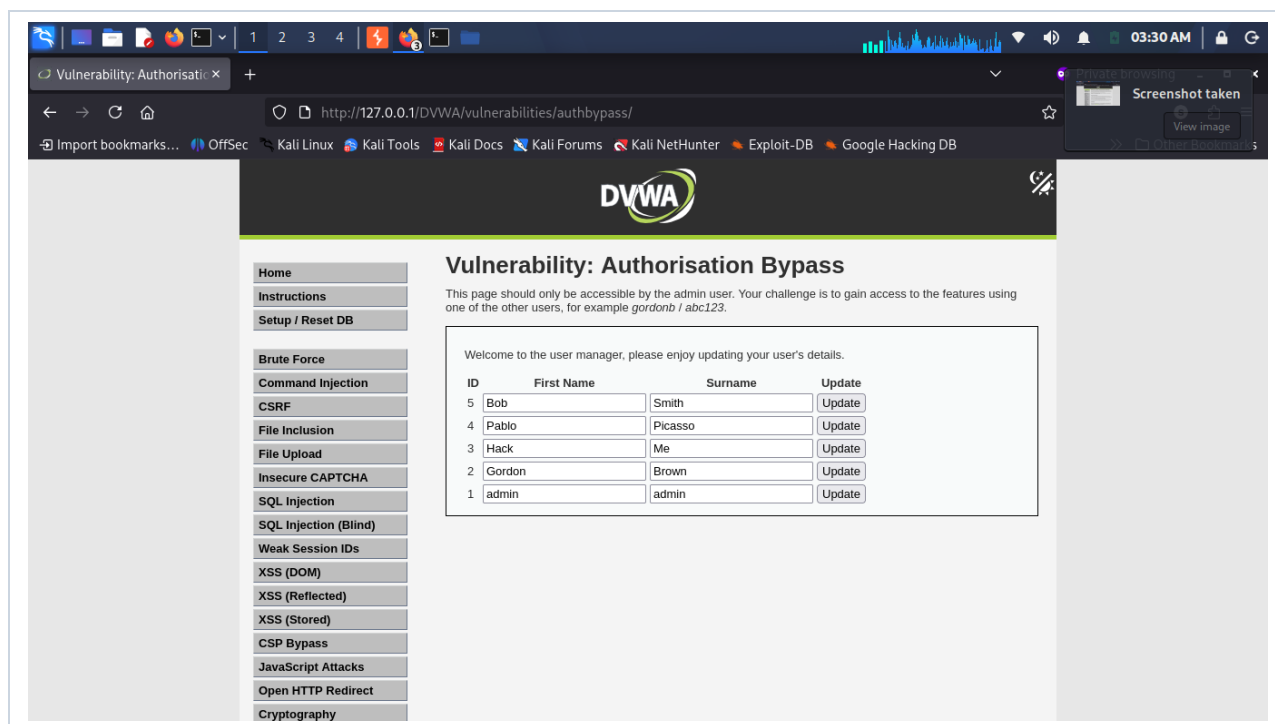
Logging in with the gordonb account.



DVWA home page after logging in as gordonb.

Step 4 – Access the restricted page

While logged in as gordonb, the authbypass page was opened directly. It was still accessible, even though gordonb is not an admin.



The restricted page accessible while logged in as gordonb, confirming the bypass.

Recommendation

Check the user role on the server for every sensitive page. Do not depend only on hiding the menu link.